

الوحدة 23: الاستجابة للحوادث (Incident Response)

(IR Phases (Preparation to Lessons Learned

الاستجابة للحوادث تمر بـ 6 مراحل رئيسية وفق إطار SANS (أو 4 مراحل حسب NIST). الهدف الأساسي: تقليل الضرر وتقليص وقت التعطل.

1. Preparation: تجهيز السياسات والأدوات والفريق قبل وقوع الحادث. يشمل إنشاء IRP (Incident Response Plan)، تدريب الفريق، تجهيز أدوات مثل SIEM و EDR.

2. Identification: اكتشاف الحادث عبر أنظمة المراقبة (IDS/IPS, SIEM) أو البلاغات من الموظفين أو العملاء. تحديد نوع الحادث ومدى تأثيره.

3. Containment: احتواء الضرر (عزل النظام المصاب، قطع الاتصال بالشبكة، أخذ صورة للذاكرة). ينقسم إلى Short-term و Long-term containment.

4. Eradication: إزالة التهديد بالكامل (حذف ملفات ضارة، إغلاق ثغرات، إزالة برمجيات خبيثة، إعادة تثبيت أنظمة).

5. Recovery: استعادة الأنظمة للعمل الطبيعي من النسخ الاحتياطية. مراقبة دقيقة للتأكد من عدم عودة التهديد.

6. Lessons Learned: تحليل الحادث وتحسين الإجراءات. كتابة تقرير مفصل (Postmortem) وتحديث السياسات والتدريب.

Incident Types

أنواع الحوادث الأمنية الشائعة:

- Malware: برمجيات ضارة (فيروسات، Ransomware).
- Phishing: هجمات التصيد الاحتيالي.
- DDoS: هجمات حجب الخدمة الموزعة.
- Insider Threat: تهديد داخلي من موظف.
- Data Breach: تسريب بيانات.

CSIRT

CSIRT (Computer Security Incident Response Team): فريق متخصص للاستجابة للحوادث. يشمل محللين أمنيين، خبير طب شرعي، مسؤول قانوني، ومدير اتصالات. يعمل الفريق وفق SOPs محددة مسبقًا.

Runbooks / Playbooks

Playbook: دليل إجراءات خطوة بخطوة للتعامل مع نوع حادث معين (مثال: Playbook لهجوم Ransomware).

Runbook: تفاصيل تقنية أكثر، مثل أوامر محددة لتشغيلها.

مثال: التقاط حركة مرور باستخدام tcpdump

```
tcpdump -i eth0 -n -s 0 -w capture.pcap host 10.0.0.5
```

يشرح الأمر كالتالي:

tcpdump : أداة التقاط الحزم.
-i eth0 : الواجهة التي نلتقط منها (eth0).
-n : لا يحل أسماء النطاقات (أسرع).
-s 0 : يلتقط الحزمة كاملة.
-w capture.pcap : يحفظ الناتج في ملف.
host 10.0.0.5 : يفلتر لالتقاط حركة هذا المضيف فقط.

مثال: تحليل سجل الأحداث في Windows

```
Get-EventLog -LogName Security -Newest 20 | Format-Table -Auto  
Get-WinEvent -FilterHashtable @{LogName='Security';ID=4625} -MaxEvents 10
```

يشرح الأمر كالتالي:

Get-EventLog -LogName Security : يعرض آخر 20 حدث من سجل الأمان.
Get-WinEvent : أمر أكثر تقدمًا لجلب الأحداث.
{LogName='Security';ID=4625} : يفلتر لأحداث ID 4625 (فشل تسجيل دخول).
-MaxEvents 10 : آخر 10 أحداث فقط.

مؤشرات الاختراق (IoC)

IoC (Indicators of Compromise): أدلة تدل على حدوث اختراق مثل: عناوين IP مشبوهة، هاشات ملفات ضارة (SHA-256)، أسماء نطاقات، أنماط حركة شاذة، مفاتيح ريجستري غير معروفة.

IoA (Indicators of Attack): أدلة تدل على هجوم قيد التنفيذ (مثل محاولات تسجيل دخول فاشلة متتالية). الفرق: IoC علامات بعد الاختراق، IoA علامات أثناء الهجوم.

مصادر أدلة الحوادث

Syslog: سجلات Linux/Unix المركزية.
Windows Event Log: سجلات الأمان والنظام والتطبيقات.
NetFlow: سجلات تدفق الشبكة.
Metadata: بيانات وصفية للملفات (حجم، تاريخ، مالك).
تطبيقات: سجلات IIS, Apache, Exchange.

(Quick Quiz (MCQ

?How many phases are in the SANS incident response lifecycle .1

- a) 4
- b) 5
- c) 6
- d) 7

Answer: c

?What is the primary goal of the Containment phase in incident response .2

- a) Identify the attacker
- b) Limit the spread and impact of the incident
- c) Eradicate all malware
- d) Restore normal operations

Answer: b

?What does CSIRT stand for .3

- a) Computer Security Incident Response Team
- b) Central Security Investigation Response Tool
- c) Cyber Security Intelligence Recovery Task
- d) Computer System Incident Recovery Team

Answer: a

?What is a tabletop exercise in incident response .4

- a) A full-scale live simulation attack
- b) A discussion-based walkthrough of an incident scenario
- c) A physical penetration test
- d) An automated vulnerability scan

Answer: b

?What does IoC stand for in threat analysis .5

- a) Internet of Computers
- b) Indicators of Compromise
- c) Input of Commands
- d) Incident of Concern

Answer: b